

K8sAttackMap

Security Audit

Kubernetes Attack Surface Analysis Report

Generated: May 04, 2026 - 20:21 IST

Cluster Context: Minikube (Local Development)

Tool: K8sAttackMap v1.0.0

Disclaimer: This report is based on automated analysis and should be reviewed by security professionals. It is not a substitute for comprehensive security audits or penetration testing.

1. Executive Summary

This report summarises automated analysis of Kubernetes RBAC configuration, workload deployments, container images, and access policies to map potential compromise paths. Results are intended to guide prioritised remediation effort.

Overall Risk Grade

Based on total discovered attack paths and choke point density.

CRITICAL
(F)

29

ATTACK PATHS FOUND

12

ENTRY POINTS

1

ESCALATION LOOPS

37%

PATHS SEVERED BY
TOP FIX

Key Findings

- **29 attack path(s)** were discovered from potential entry points to sensitive targets.
- The highest-impact single fix is **Group:cluster-scoped:system:serviceaccounts** — addressing it eliminates **37%** of all known paths.
- **1 privilege escalation loop(s)** detected; these allow attackers to re-acquire access after partial remediation.
- **240 pod(s)** carry known CVEs. See Section 5 for details.

2. Critical Choke Points

A choke point is a node whose removal from the graph would sever the most attack paths. Fixing the top choke point first gives the maximum security return per engineering hour.

Primary Choke Point

Group:cluster-scoped:system:serviceaccounts
Type: **Group** | Namespace: **cluster-scoped**

37%
paths eliminated
by single fix

Top 5 Choke Points by Impact

#	Node ID	Type	Namespace	Paths Severed	Weighted Score
#1	Group:cluster-scoped:system:serviceaccounts	Group	cluster-scoped	11	99.0
#2	ServiceAccount:multipath-test:attacker-sa	ServiceAccount	multipath-test	5	45.0
#3	ServiceAccount:default:default	ServiceAccount	default	4	36.0
#4	Role:multipath-test:role-alpha	Role	multipath-test	2	18.0
#5	Role:multipath-test:role-beta	Role	multipath-test	2	18.0

3. Critical Attack Path

The path below represents the shortest, highest-risk route from an attacker-controlled entry point to a sensitive target. Each row is one hop; lower edge weight = easier traversal.

Hop	Source Node	Relationship	Target Node	Weight
1	Pod:multipath-test:attacker-pod	uses_sa	ServiceAccount:multipath-test:attacker-sa	6.0
2	ServiceAccount:multipath-test:attacker-sa	bound_to	Role:multipath-test:role-alpha	9.2
3	Role:multipath-test:role-alpha	can_access	Secret:multipath-test:crown-jewel	9.9

4. Remediation Plans

Each plan targets one choke point. Audit commands are safe to run on live clusters. Enforcement commands should be reviewed and tested in a non-production environment first. Commands marked **[DESTRUCTIVE]** may impact running workloads.

1. Group:cluster-scoped:system:serviceaccounts

Group [Group:cluster-scoped:system:serviceaccounts] is bound to a ClusterRole that appears on 11 attack path(s). Groups are not K8s API objects — remediation targets the binding(s) that reference this group.

AUDIT FIRST (SAFE ON LIVE CLUSTER)

```
# Groups are not kubectl resources. Find the bindings that reference this group:
kubectl get clusterrolebindings -o json | jq '.items[] |
select(.subjects[]?.name=="system:serviceaccounts") | .metadata.name'
kubectl get rolebindings -A -o json | jq '.items[] |
select(.subjects[]?.name=="system:serviceaccounts") | {ns:.metadata.namespace,
name:.metadata.name}'
```

THEN ENFORCE

```
# Delete or restrict the ClusterRoleBinding that grants this group elevated access:
kubectl delete clusterrolebinding <binding-name-from-audit-above>
# Or replace the bound ClusterRole with a less privileged one:
kubectl patch clusterrolebinding <binding-name> --type=json -p
' [{"op": "replace", "path": "/roleRef/name", "value": "<least-privilege-role>"} ]'
```

Plan contains destructive actions – review before executing.

2. ServiceAccount:multipath-test:attacker-sa

ServiceAccount [ServiceAccount:multipath-test:attacker-sa] is a choke point (paths=5, weighted score=45.0); hardening can significantly reduce attack routes.

AUDIT FIRST (SAFE ON LIVE CLUSTER)

```
kubectl get serviceaccount attacker-sa -n multipath-test -o yaml
# Check which pods use this ServiceAccount (if automount is enabled, these will lose
token access):
kubectl get pods -n multipath-test -o
jsonpath='{range .items[?(@.spec.serviceAccountName=="attacker-
sa")]}{.metadata.name}{"\n"}{end}'
kubectl get pod -n multipath-test -o yaml | grep -A5 "serviceAccountName: attacker-sa"
```

THEN ENFORCE

```
kubectl patch serviceaccount attacker-sa -n multipath-test -p
 '{"automountServiceAccountToken": false}'
# Restart affected pods so the change takes effect:
kubectl rollout restart deployment/<owner-deployment> -n multipath-test
```

3. ServiceAccount:default:default

ServiceAccount [ServiceAccount:default:default] is a choke point (paths=4, weighted score=36.0); hardening can significantly reduce attack routes.

AUDIT FIRST (SAFE ON LIVE CLUSTER)

```
kubectl get serviceaccount default -n default -o yaml
# Check which pods use this ServiceAccount (if automount is enabled, these will lose
token access):
kubectl get pods -n default -o
jsonpath='{range .items[?(@.spec.serviceAccountName=="default")]}{.metadata.name}{"\n"}{end}'
kubectl get pod -n default -o yaml | grep -A5 "serviceAccountName: default"
```

THEN ENFORCE

```
kubectl patch serviceaccount default -n default -p '{"automountServiceAccountToken":
false}'
# Restart affected pods so the change takes effect:
kubectl rollout restart deployment/<owner-deployment> -n default
```

4. Role:multipath-test:role-alpha

Role [Role:multipath-test:role-alpha] is a high-traffic choke point (paths=2, score=18.0). It grants overly broad permissions; tightening it will sever the most attack paths.

AUDIT FIRST (SAFE ON LIVE CLUSTER)

```
kubectl get role role-alpha -n multipath-test -o yaml
kubectl auth can-i --list --as=system:serviceaccount:multipath-test:<bound-sa>
kubectl get rolebindings -n multipath-test -o json | jq '.items[] |
select(.roleRef.name=="role-alpha") | .metadata.name'
```

THEN ENFORCE

```
# Create a least-privilege replacement that allows only required verbs/resources:
kubectl edit role role-alpha -n multipath-test
# Or apply a pre-reviewed replacement:
kubectl apply -f least-privilege-role-role-alpha.yaml
```

5. Role:multipath-test:role-beta

Role [Role:multipath-test:role-beta] is a high-traffic choke point (paths=2, score=18.0). It grants overly broad permissions; tightening it will sever the most attack paths.

AUDIT FIRST (SAFE ON LIVE CLUSTER)

```
kubectl get role role-beta -n multipath-test -o yaml
kubectl auth can-i --list --as=system:serviceaccount:multipath-test:<bound-sa>
kubectl get rolebindings -n multipath-test -o json | jq '.items[] |
select(.roleRef.name=="role-beta") | .metadata.name'
```

THEN ENFORCE

```
# Create a least-privilege replacement that allows only required verbs/resources:
kubectl edit role role-beta -n multipath-test
# Or apply a pre-reviewed replacement:
kubectl apply -f least-privilege-role-role-beta.yaml
```

5. Privilege Escalation Loops

Circular permission chains allow attackers to re-acquire access even after credentials are rotated. Break at least one edge in each loop to prevent cyclic escalation.

ID	Severity	Nodes	Circular Path
#1	LOW	3	Pod:default:loop-pod → ServiceAccount:default:loop-sa → Role:default:loop-role → Pod:default:loop-pod

6. Pod Vulnerability Summary

Container images were scanned via Trivy. The table below lists pods with known CVEs, sorted by CVE count. Pods on critical attack paths are marked.

Pod	Namespace	CVE Count	Max CVSS	On Attack Path
Pod:default:nginx-deployment-7b9ccfd4cc-pknq4	default	448	9.8	No
Pod:default:nginx-deployment-7b9ccfd4cc-c4j62	default	448	9.8	No
Pod:default:nginx-deployment-7b9ccfd4cc-vhrbx	default	448	9.8	No
Pod:kube-system:storage-provisioner	kube-system	125	10.0	No
Pod:kube-system:kube-proxy-5x715	kube-system	48	10.0	No
Pod:kube-system:coredns-7d764666f9-x9dd5	kube-system	33	10.0	No
Pod:kube-system:etcd-minikube	kube-system	20	10.0	No
Pod:kube-system:kube-apiserver-minikube	kube-system	14	10.0	No
Pod:kube-system:kube-controller-manager-minikube	kube-system	14	10.0	No
Pod:kube-system:kube-scheduler-minikube	kube-system	13	10.0	No
Pod:default:loop-pod	default	10	6.7	No
Pod:multipath-test:attacker-pod	multipath-test	1	0.0	[!] YES